CIS LINUX AUDIT · VERSIÓN 1.0.0

Guía de Ejecución de Auditoría

Procedimiento en 5 fases: inventario, conectividad, recolectores, precheck y auditoría completa con filesystem profundo, con su interpretación.

Versión 1.0.0 | Fecha 2026-11-10 | Versión operativa | Auditoría de solo lectura

Contenido

1. Antes de empezar
2. Fases de la auditoría
3. Resumen de comandos

1. Antes de empezar

Guía paso a paso para ejecutar una auditoría CIS con la versión 1.0.0. Todos los comandos se ejecutan desde el directorio del proyecto en el controlador. La instalación de recolectores en los servidores la hace Infraestructura con su propio documento. En los ejemplos el servidor se llama `VM-ORA9-PRD-01` y la lista de varios servidores `H1,H2,H3,H4`.

Rol	Responsabilidad
Auditor (controlador)	Inventario, preparar, plan, precheck, ejecutar, reportes, custodia de resultados. Nunca instala nada en el servidor.
Infraestructura (root en el servidor)	Cuenta srvinnops, instalación y retiro de recolectores y sudoers, verificación PRE/POST de privilegios.
Seguridad / responsable de línea base	Exclusiones (columna del Excel), listas aprobadas y decisiones organizacionales.

Reglas de oro

- No continuar si un SHA-256 no coincide.
- Siempre con --filesystem-profundo en precheck y ejecutar.
- Un ERROR DE AUDITORÍA se corrige y se repite: no se interpreta como incumplimiento.
- Cada ejecución crea una carpeta nueva en results/: nunca se reutiliza ni se sobrescribe.

2. Fases de la auditoría

FASE 1 — Revisar el inventario de servidores

OBJETIVO

Confirmar que el servidor que se va a auditar está registrado en `inventory/hosts.yml`. Ese archivo es la lista de servidores que la herramienta puede auditar: para cada uno indica su nombre, su IP y su tipo de sistema operativo. La entrega ya lo trae con los servidores vigentes; solo se edita para agregar un servidor nuevo o corregir una IP.

COMANDO

a) Ver qué servidores están registrados:

```
cat inventory/hosts.yml
```

b) Si el servidor no está, agregarlo debajo del grupo que corresponde a su sistema operativo (respetar la sangría con espacios, sin tabuladores):

Grupo del inventario	Sistema operativo del servidor
rhel_oracle_8	Oracle Linux 8 o RHEL 8
rhel_oracle_9	Oracle Linux 9 o RHEL 9
sles_15	SUSE Linux Enterprise 15

```
vi inventory/hosts.yml

# ejemplo: agregar VM-ORA9-PRD-01 (Oracle Linux 9) con su IP
    rhel_oracle_9:
      hosts:
        VM-ORA9-PRD-01:             # nombre que se usará en --limit
          ansible_host: 10.0.0.21     # IP del servidor
```

La cuenta (`srvinnops`) y la llave (`~/.ssh/srvinnops`) ya están definidas una sola vez al inicio del archivo, para todos los servidores: no se repiten por servidor.

c) Comprobar el inventario **sin conectarse** a ningún servidor:

```
python3 src/auditar.py plan --limit VM-ORA9-PRD-01
```

RESULTADO ESPERADO

El comando muestra `DRY-RUN: no se ha contactado ningún host`, el nombre del servidor y todas las líneas en `[OK]`. Eso confirma que el servidor está bien registrado.

QUÉ HACER SI FALLA

- `no es un host del inventario` → el nombre en `--limit` no coincide exactamente con el del archivo (mayúsculas, guiones).
- `falta completar ansible_host` → falta la IP del servidor.
- Error de formato YAML → revisar la sangría del bloque agregado (solo espacios).
- `data/ no corresponde` → alguien modificó un Excel de línea base: ejecutar `python3 src/auditar.py preparar` y repetir.

FASE 2 — Validar conectividad

OBJETIVO

Comprobar el acceso SSH por llave de la cuenta de auditoría, sin contraseña.

COMANDO

```
ssh -o BatchMode=yes -o PasswordAuthentication=no -i ~/.ssh/srvinnops
srvinnops@<ansible_host> 'hostname; cat /etc/os-release | head -3'
```

RESULTADO ESPERADO

Devuelve el hostname y el sistema operativo sin pedir contraseña.

QUÉ HACER SI FALLA

- `Host key verification failed` → validar la huella del servidor y registrarla en known_hosts (host_key_checking=True).
- `Permission denied (publickey)` → la llave no está autorizada para srvinnops: solicitar a Infraestructura.
- Timeout → revisar red/firewall o bastión (`ansible_ssh_common_args` con ProxyJump).

FASE 3 — Confirmar que los recolectores están instalados

OBJETIVO

Antes de auditar, Infraestructura debe tener instalados en cada servidor el recolector principal y el recolector de filesystem profundo, con sus archivos sudoers. Este procedimiento **no se ejecuta desde el controlador**: está completo en el documento Instalación de Collectors.

COMANDO

Archivo en el servidor	Versión
/usr/local/libexec/cis-audit/cis-audit-collect	1.8.0
/etc/sudoers.d/cis_audit	1.8.0
/usr/local/libexec/cis-audit/cis-audit-collect-fs	1.1.0

Archivo en el servidor	Versión
/etc/sudoers.d/cis_audit_fs	1.1.0

RESULTADO ESPERADO

Infraestructura confirma la instalación según ese documento. La verificación real la hace el precheck de la fase 4.

QUÉ HACER SI FALLA

Si Infraestructura no ha instalado algún archivo, no continuar: el precheck lo detectará y bloqueará la auditoría.

FASE 4 — Precheck con filesystem profundo

OBJETIVO

Verificar, en solo lectura y sin evaluar controles, que cada servidor está listo: conexión SSH, sistema operativo y confianza de los dos recolectores. Se pueden incluir hasta 10 servidores separados por coma.

COMANDO

```
python3 src/auditar.py precheck --filesystem-profundo --limit VM-ORA9-PRD-01
# varios servidores
python3 src/auditar.py precheck --filesystem-profundo --limit H1,H2,H3,H4
```

Cómo interpretar la salida (una sección por servidor):

Línea de la salida	Qué significa	Valor correcto
SSH=	Conexión por llave con srvinnops	OK
SO= / benchmark seleccionado=	Sistema detectado y Benchmark CIS que se usará	El SO real del servidor
sudo -n general=	srvinnops no tiene sudo general (es lo esperado)	no
recolector principal:	Archivo, permisos, SHA-256 y sudoers del recolector principal	CONFIABLE
recolector FS (filesystem profundo):	Lo mismo para el recolector de filesystem	CONFIABLE
impacto previsto / inodos	Informativo: tamaño de lo que se recorrerá. No decide nada	—
PARTE 1 / PARTE 2 / GLOBAL	Informativo: cuántos controles se evaluarán	—
gate de ejecución:	Decisión final: si se puede ejecutar la auditoría	PERMITIDO

RESULTADO ESPERADO

Todos los servidores con `SSH=OK`, ambos recolectores **CONFIABLE** y `gate de ejecución: PERMITIDO`; el comando termina con código 0 (`echo $?`).

QUÉ HACER SI FALLA

Lo que aparece	Causa	Qué hacer
SSH=FALLIDO	Red, firewall o llave no autorizada	Repetir la fase 2.
NO_INSTALADO	El recolector no existe en el servidor	Infraestructura lo instala (fase 3).
NO_CONFIABLE	SHA-256, dueño, permisos o ACL no coinciden	Infraestructura reinstala la versión correcta. No continuar.
NO_AUTORIZADO	El sudoers no autoriza el recolector a srvinnops	Infraestructura revisa /etc/sudoers.d/.
SO_NO_CORRESPONDE	El grupo del inventario no coincide con el SO real	Mover el servidor al grupo correcto (fase 1).
gate BLOQUEADO (código 4)	Alguna de las anteriores	Corregir y repetir el precheck.
Código 2	Nombre en --limit inexistente o más de 10 servidores	Revisar --limit.

FASE 5 — Auditoría completa con filesystem profundo

OBJETIVO

Ejecutar la auditoría: vuelve a hacer el precheck, recolecta la evidencia (incluido el recorrido completo de filesystem), evalúa los controles y genera los reportes. Solo lectura: no modifica nada en los servidores. Se ejecuta **un servidor por ejecución**, para obtener un reporte por servidor.

COMANDO

```
python3 src/auditar.py ejecutar --filesystem-profundo --limit VM-ORA9-PRD-01
# varios servidores: una ejecución (y un reporte) por servidor
for h in H1 H2 H3 H4; do
  python3 src/auditar.py ejecutar --filesystem-profundo --limit "$h"
done
# informe consolidado para el proveedor (últimas ejecuciones de cada servidor)
python3 src/auditar.py informe-proveedor
```

> **Un reporte por servidor**
>
> Si se pasan varios servidores en un mismo `--limit` de `ejecutar`, la herramienta genera **un solo reporte combinado**. Para tener el reporte de cada servidor, ejecutar uno por uno como en el ejemplo. El `informe-proveedor` consolida después la última ejecución de cada servidor.

Cómo interpretar el resumen final:

Dato del resumen	Qué significa	Valor esperado
CUMPLE / NO_CUMPLE / CUMPLE_PARCIALMENTE	Resultado técnico CIS de los controles	Informativo
NO_APLICA	Controles que no aplican al servidor, con causa explícita	Informativo
REQUIERE_VALIDACION_MANUAL / REQUIERE_EVIDENCIA_ORGANIZACIONAL	Controles que no se pueden concluir solo con evidencia técnica	Revisar en el reporte
ERROR_DE_AUDITORIA	Problemas del proceso (no del servidor)	0
errores_por_falta_de_privilegios	Controles sin evidencia por permisos	0
pendientes_filesystem_profundo	Controles de filesystem sin evaluar	0
cumplimiento_cis_tecnico	% de cumplimiento CIS sin aplicar exclusiones	Informativo
Cumplimiento final de línea base	% de cumplimiento después de las exclusiones de Infraestructura	Informativo
Cobertura de validación	% de controles con conclusión	Lo más alto posible

Dónde quedan los resultados: `results/<FECHA>_<SERVIDOR>/reports/` (`cis_hardening_audit_<SERVIDOR>.html` y `.xlsx`) y `results/informe_proveedor/<FECHA>/` (informe para el proveedor en HTML y PDF). En el reporte HTML, cada control trae lo que exige el CIS, lo encontrado en el servidor y qué falta.

RESULTADO ESPERADO

Código 0, `ERROR_DE_AUDITORIA=0` , `errores_por_falta_de_privilegios=0` y `pendientes_filesystem_profundo=0` en todos los servidores.

QUÉ HACER SI FALLA

Lo que aparece	Causa	Qué hacer
EJECUCIÓN ABORTADA / código 5	El gate bloqueó: no se ejecutó ningún control	Repetir la fase 4 y corregir.
Código 3	Falló una validación previa	Ver results/<RUN>/logs/ejecucion.log.
ERROR_DE_AUDITORIA mayor que 0	Problema del proceso (conexión, permisos, salida no interpretable)	Ver el detalle en el reporte (sección Errores de auditoría), corregir y ejecutar de nuevo. No es un incumplimiento.
HOST_SIN_EVIDENCIA	El servidor dejó de responder durante la recolección	Ejecutar de nuevo ese servidor.

Lo que aparece	Causa	Qué hacer
pendientes_filesystem_profundo mayor que 0	Se ejecutó sin --filesystem-profundo o el recolector FS no era CONFIABLE	Repetir con --filesystem-profundo tras un precheck correcto.
PDF no generado: WeasyPrint…	Falta WeasyPrint en el controlador	Se entrega el HTML o se instala WeasyPrint.

3. Resumen de comandos

Paso	Comando
Comprobar inventario (sin conexión)	python3 src/auditar.py plan --limit VM-ORA9-PRD-01
Precheck	python3 src/auditar.py precheck --filesystem-profundo --limit VM-ORA9-PRD-01
Auditoría completa	python3 src/auditar.py ejecutar --filesystem-profundo --limit VM-ORA9-PRD-01
Informe para el proveedor	python3 src/auditar.py informe-proveedor